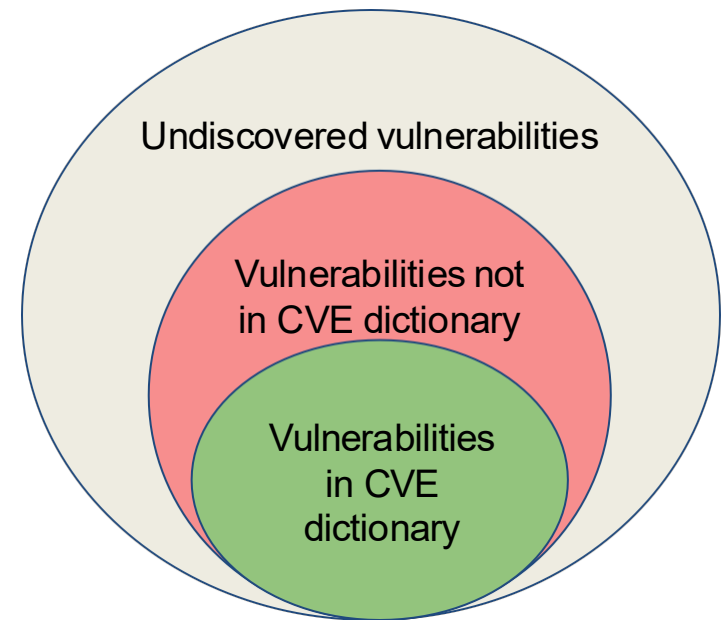


Communicating vulnerabilities

Mihai Ordean

CVE what?

- Common Vulnerabilities and Exposures
 - List of entries of publicly known cybersecurity vulnerabilities
 - Proposed in 1999 by MITRE Corporation
- Does not cover silent “bug” fixes or undiscovered vulnerabilities
- Publicly available in the form of feeds
 - MITRE Corporation
 - National Vulnerability Database (NVD)
 - Additional metadata



* not to scale

How does the CVE system work?

- CVE submissions/entries are brief and don't include technical data or information about risks, impacts, and fixes.
- Risks, impacts, and fixes details appear in
 - U.S. National Vulnerability Database (NVD)
 - CERT/CC Vulnerability Notes Database
 - various lists maintained by vendors and other organizations
- CVE entries receive unique CVE IDs give users a reliable way to recognize unique vulnerabilities and coordinate the development of security tools and solutions.

CVE identifiers (CVE IDs)

- CVE identifiers are assigned by a **CVE Numbering Authority (CNA)**
 - Approximately 100 CNAs exist: MITRE, security companies, research organizations, IT vendors such as Red Hat or Microsoft.
- **CNAs** manage blocks of CVE IDs, which the CNAs hold in reserve to attach to new issues as they're discovered.
- Thousands of CVE IDs are issued every year. Anyone—a vendor, a researcher, or just a user—can discover a security flaw. Once discovered information about the flaw makes its way to a CNA which will issue a CVE ID.

The CVE challenge – growing vulnerabilities

Vulnerabilities by type & year



What qualifies as a CVE?

- **Be independently fixable**
 - The flaw can be fixed independently of any other bugs.
- **Be acknowledged by the affected vendor or documented**
 - The software or hardware vendor acknowledges the bug's existence and confirms that it negatively impacts security.
 - A vulnerability report that demonstrates both the negative impact of the bug *and* that it violates the security policy of the affected system.
- **Affect only one codebase**
 - Each codebase gets a separate CVE.

The Common Vulnerability Scoring System

- A set of **open standards** for assigning a number to a vulnerability to assess its severity.
- **Scores** range from 0.0 to 10.0, with higher numbers representing a higher degree of severity.

CVE content

- CVE-ID: CVE-YEAR-NNNNNNN
- Description of the issue
- Estimated severity (CVSS - Common Vulnerability Scoring System)
 - Low to Critical, 0.0 to 10.0
- Estimated impact and domain scores
 - e.g. “Attack Vector”, “User Interaction”, “Scope”, “Confidentiality”, ...
 - <https://nvd.nist.gov/vuln-metrics/cvss/v3-calculator>
- Affected products, version numbers (CPEs - Common Platform Enumeration)
 - eg: cpe:2.3:a:openssl:openssl:1.1.0g:*:*:*:*:*
 - https://en.wikipedia.org/wiki/Common_Platform_Enumeration
 - **Key piece for automation**
- List of reference links
 - Exploits, patches, bug entry, mitigation, advisories...
- Vulnerability Type (CWE - Common weakness enumeration)
 - e.g. “buffer overflow”, “pointer issues”

Game Time

- **Objective:** Grasp the lifecycle of a CVE!
- **Activity:** Setup and play the game for 30-40 min.
- **Game debrief by each group/team:**
 - Which CVE did you chose and how did you modify it?
 - How did you compute and how accurate was CVSS score?
 - How efficient were you in solving the CVE(s)?
 - Any particular observations and/or experiences?

Game rules

Setup:

You pick a **single CVE** card at random **per game** and perform the actions described on it. Make sure you can keep track of the credibility points and the action outcomes/events throughout the game.

Resources:

1. **Action Tokens.** Each player receives 3x tokens at the beginning of each round to spend freely during that round to perform actions. Each action its token price listed on the Action Card.
2. **Credibility.** Players collect credibility points when performing actions. Credibility points contribute to the player ranking after the game ends.

Gameplay:

Each game runs for 10 rounds. Modifiers can be used to extend or reduce this number. A round finishes when all players run out of round tokens or refuse to perform more actions. Round tokens cannot be passed between rounds. Action outcomes/events persist between rounds. The goal of the game is to address the CVE by executing the Security Researcher's **Disclosure**, the Incident Response Team **Deploy mitigation** and Journalist's **Publish report** within at most **one round from each-other**.

Team Victory:

All players win if the CVE is successfully addressed before the number of rounds reaches maximum. If the CVE is not mitigated then the game is lost.

Individual Victory:

Players earn individual recognition based on how well they fulfill their role-specific goals by collecting credibility points. The player with the most credibility wins the Individual victory in the event of a Team Victory. In the case of a Team Loss the player with the most credibility is ranked last: they promoted personal gains while sabotaging the CVE resolution.